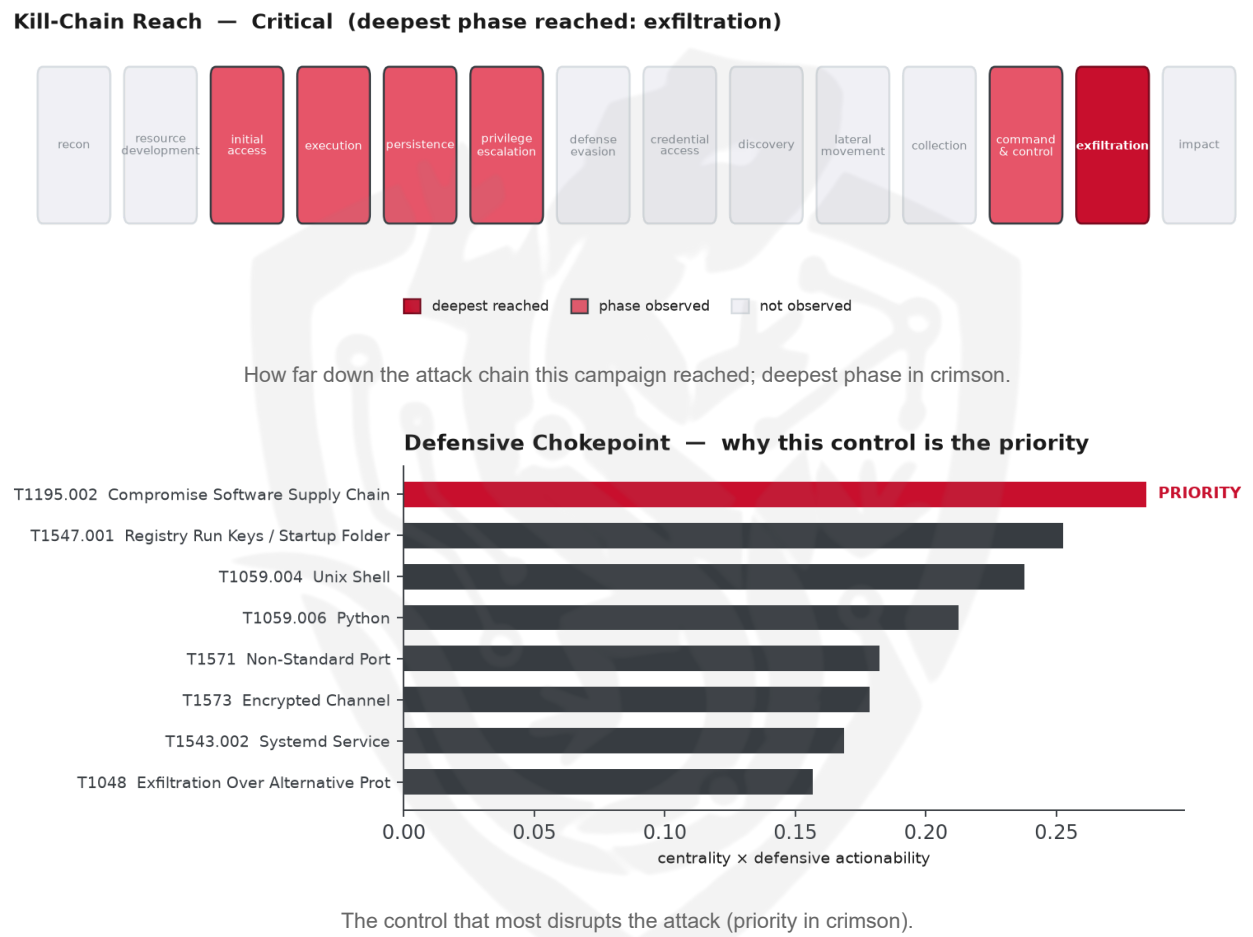


THREAT REPORT: UNKNOWN_ADVERSARY

CAMPAIGN DELIVERING MIASMA BOTNET LOADER

Visual Summary



Summary

The observed cluster of activity is delivering Miasma botnet loader through compromised npm packages in the AsyncAPI namespace. The targeted country and sectors are not specified, but the threat actor is exploiting various techniques to compromise the software supply chain. Priority should be given to verifying the software supply chain integrity to prevent further compromise. The threat actor's use of compromised npm packages highlights the importance of monitoring third-party dependencies and update channels.

Threat Overview

The threat actor, whose identity is not specified, is utilizing the Miasma malware family to compromise systems. Although the central CVE is not identified, the actor is leveraging various techniques, including

JavaScript and Unix Shell execution, to achieve their goals. The victimology of this campaign is not well-defined, but the use of compromised software packages suggests a potential focus on developers and organizations using the affected npm packages.

Attack Chain and Priority Control

The observed techniques used by the threat actor form a complex chain, starting with the compromise of the software supply chain and proceeding through various stages, including deobfuscation, proxying, and exfiltration. The priority technique in this chain is T1195.002 Compromise Software Supply Chain, which serves as a chokepoint for the actor's activities. To mitigate this threat, the priority control is to: Verify software supply chain integrity (signing, SBOM); pin and monitor third-party dependencies and update channels.

Infrastructure and Corroboration

There is no observed hosting provider or ASN associated with this campaign, and no malware families have been corroborated by abuse.ch. Additionally, no indicators have been flagged with high confidence by AbuseIPDB, with the highest confidence seen being 0%.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1059.007 JavaScript
- T1140 Deobfuscate/Decode Files or Information
- T1090 Proxy
- T1568 Dynamic Resolution
- T1102 Web Service
- T1041 Exfiltration Over C2 Channel
- T1547.001 Registry Run Keys / Startup Folder
- T1048 Exfiltration Over Alternative Protocol
- T1059.004 Unix Shell
- T1571 Non-Standard Port
- T1027 Obfuscated Files or Information
- T1573 Encrypted Channel
- T1195.002 Compromise Software Supply Chain
- T1059.006 Python
- T1132 Data Encoding
- T1071.001 Web Protocols
- T1543.002 Systemd Service
- T1105 Ingress Tool Transfer
- T1564.001 Hidden Files and Directories

- T1008 Fallback Channels

Analytical Scores

- Priority technique (graph chokepoint): T1195.002 Compromise Software Supply Chain (centrality 0.2846).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4438; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Rocke	0.4438
Higaisa	0.3675
APT19	0.3467
RedEcho	0.3467
Tropic Trooper	0.3407

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator
URL	hxxps://ethereum-rpc[.]publicnode[.]com
URL	hxxp://85[.]137[.]53[.]71:8080/api/v1/beacon
URL	hxxp://85[.]137[.]53[.]71:8080/api/v1/file-result
URL	hxxp://85[.]137[.]53[.]71:8080/api/v1/file-content/
Hash	34014776d3d3ff11bc4439b02fd7ac0f02a887eb3a052eeafff236e2f6db8ad1

Type	Indicator
Hash	082d733db0687dcd768104972b065d4b58cb1e6043688c6c20fa3702337f36ab
Hash	bfaeb987faa6de2b5a5eb63b1233d055215b09b0349a9394f2175fd7cdf385e4
Hash	9b2e65db653ca8575c9b10eefb9a80c6006404812c2ec212bf5675e3c690233b
Hash	d425e4583cc6185d41e95c45eda00550045a5d1919b9a012236a4520d009dbd7
Hash	6e78713b75bd34828d49896176627f7face7aa9036cd874f2e02d9f23a9a9c71
Hash	b270bdf8e2274ea1af0a6eed74d8f10e5fe61012d6cc226a43cc7cc7fd9f6292
Hash	b9993a8ad0518849416798cf29668256ccb96598fc4423501ccab5312812653a
Hash	8351d251cf0b5a0bd82242deaa0a14e3e1394418d55c0f4259dac4303b79fc0c
Hash	550af477c12192a22f5c9edb9c8081c0a789b3a1a2992a7ecb157cca1c975e10
Hash	24b9ee242f21a73b55f7bb3297eafb33c60840907386b542ed79fc6b72365168
Hash	9e214f38537e69bf51c7fa1ddd35ae495e9cb897231ec010baf9e4f29407ee9a
Hash	9f1a709310824f9110c6203d861a721ebefba8b204a8657057fe57efb961c850
Hash	3eab3ec9304aa26081358330491d3cfef55cc245

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1195.002 Compromise Software Supply Chain (initial-access)
- **Observed here:** T1195.002 Compromise Software Supply Chain was the only initial-access technique observed in this campaign, so the pivot is projected from cross-actor behaviour.
- **Projected pivot:** T1566 Phishing (initial-access)
- **Basis:** 9 of 170 documented groups that use Compromise Software Supply Chain also use Phishing (conditional 0.82, lift 1.4, i.e. ~1.4x base rate). Strongest same-tactic neighbour.

The actor could pivot to T1566 Phishing to maintain their objective by attempting to trick users into divulging sensitive information or installing malware, potentially exploiting the trust established through previous supply chain compromise attempts. This technique may be used to target specific individuals or groups within the organization, and the actor would likely tailor their phishing campaigns to increase the chances of success. To counter this potential pivot, the organization should enable attachment sandboxing

and link rewriting; block macro-enabled Office docs from the internet zone; deploy a user report-phish button.

Also plausible (same tactic): T1133 External Remote Services (n=7, lift 3.9), T1190 Exploit Public-Facing Application (n=7, lift 2.5)

Detection and hardening for the pivot (T1566 Phishing)

- **Telemetry:** Email security gateway logs; Endpoint (Office child processes); Proxy/DNS
- **Detect:**
 - Office apps (winword/excel) spawning script or LOLBIN child processes
 - Mark-of-the-Web bypass; ISO/IMG/LNK/HTML-smuggling attachments detonating
 - First-contact domains and newly registered domains in mail links
- **Harden:**
 - Attachment sandboxing; block high-risk types (iso, img, lnk, htm) at the gateway
 - Attack-surface-reduction rules for Office child processes; user reporting button
- **MITRE:** M1049 Antivirus/Antimalware, M1031 Network Intrusion Prevention, M1017 User Training, M1021 Restrict Web-Based Content · DS0015 Application Log, DS0009 Process, DS0029 Network Traffic